

RDP Brute-Force Attack response

Intrusion · **High** severity · SOC IR Playbook

Incident type	Credential Attack - RDP Login Abuse
Severity	High
Priority	Critical if access is gained
Detection sources	SIEM, Windows Security Event Logs, EDR, IDS/IPS, Firewall logs, Threat Intel

Scenario

An attacker launches a brute-force or password spraying attack against internet-exposed or internal RDP services to gain access using weak or reused credentials. Successful access may lead to lateral movement, malware deployment or data exfiltration.

MITRE ATT&CK

T1021.001, T1078, T1110.001

Preparation

Restrict RDP exposure Use VPN, Zero Trust access or restrict via firewall Enforce strong authentication Use MFA and disable default admin accounts Monitor RDP login events Enable logging of Event ID 4625 (failed logins) and 4624 (success) Apply account lockout policy Limit the number of failed login attempts Deploy honeypots or decoys Detect brute-force attempts proactively on fake systems

Detection & Analysis

Alert from SIEM or EDR Spike in failed RDP login attempts, password spraying behaviour Review Event Logs Filter by Event ID 4625 and identify common usernames and IPs Correlate successful logins Determine if brute-force succeeded and privilege was escalated Analyse attacker IPs Check geolocation, reputation and reoccurrence in other systems

Containment

Block attacker IPs At firewall, IDS or VPN gateway Disable affected accounts Lock or reset accounts that were targeted or compromised Isolate affected hosts If lateral movement or malware deployment is suspected Throttle or disable RDP Temporarily disable RDP on high-risk systems until secured

Eradication

Remove unauthorised access Kill sessions, reset passwords and revoke tokens or certificates Patch exposed systems Update RDP services and OS to prevent exploits (e.g., BlueKeep) Clean persistence mechanisms Check for new scheduled tasks, services or registry keys added by attacker Validate no lateral movement Use EDR or log review to ensure attacker did not spread internally

Recovery

Reinstate secure RDP access Only via VPN or bastion host with MFA Notify users or IT teams Alert those impacted by the attempted logins or credential resets Monitor closely post-incident Watch for continued brute-force activity or targeted retries Conduct password audit Prompt company-wide password hygiene checks if weak credentials were used

Lessons Learned & Reporting

Analyse timeline Review when attack started, when it was detected and how quickly it was stopped Update SIEM rules Improve detection of brute-force indicators and high-failure thresholds Revise access policies Implement stricter controls over RDP use across the organisation Share findings With internal stakeholders and, if required, external authorities or vendors Test security controls Verify detection, prevention and response worked as expected or need tuning

Tools typically involved

SIEM (e.g., Splunk, Sentinel, QRadar); EDR (e.g., CrowdStrike, Microsoft Defender for Endpoint, Cortex XDR); Firewall and VPN logs (e.g., Fortinet, Palo Alto, Cisco ASA); Windows Event Viewer (Security Logs: 4624, 4625, 4648, 4672); Threat intelligence platforms (for IP enrichment); Brute-force detection scripts or SOAR playbooks

Success metrics (SLA targets)

Detection Time <5 minutes from brute-force pattern onset Containment Time <30 minutes from confirmation
Credential Reset Time <2 hours for compromised or targeted accounts Exposure Time No unauthorised RDP access exceeding 15 minutes RDP Lockdown Coverage 100% of internet-facing RDP endpoints secured or removed